

iSend Global

Information Security Master Policy

Document ID	ISEND-InfoSec-MASTER-001
Version	1.3
Classification	CONFIDENTIAL
Status	Approved
Effective Date	2023-05-10
Next Review Date	2027-05-01
Document Owner	CISO
Approved By	CEO
Frameworks	ISO 27001:2022 SOC 2 Type II

*CONFIDENTIAL — This document contains sensitive security information.
Unauthorized disclosure, reproduction or distribution is strictly prohibited.*

Document Control and Version History

Version	Date	Author	Change Description
1.0	2023-05-01	Suresh Bhattarai	Initial version — ISMS establishment
1.1	2024-04-20	Suresh Bhattarai	Update section 1, 3, and 9
1.2	2025-07-02	Biraj Khatri	Updated section 1, 2.1, 7.2 and 10
1.3	2026-05-05	Biraj Khatri Aashish Adhikari	Updated SOC 2 Type II completion date – section 3 Added section 7.3

Policy Approved By

By approving this Policy, executive leadership confirms their commitment to information security and the ISMS as described herein.

Role	Name	Date
Chief Executive Officer	Purushottam Poudyal	2026-05-07
Chief Operating Officer	Akriti Lamichhane	2026-05-07
CISO / Head of InfoSec	Aashish Adhikari 	2026-05-07

Contents

- 1. Purpose 4
- 2. Scope 4
 - 2.1 Organizational Scope 4
- 3. Information Security Policy Statement 4
- 4. Governance and Accountability..... 5
 - 4.1 Roles and Responsibilities..... 5
 - 4.2 ISMS Committee..... 5
- 5. Information Security Risk Management 5
 - 5.1 Risk Assessment 5
 - 5.2 Risk Treatment 6
 - 5.3 Statement of Applicability 6
- 6. Information Security Objectives..... 6
- 7. Subordinate Policy Framework 7
 - 7.1 Domain-specific Policy List 7
 - 7.2 AI Policy 8
 - 7.3 Distributed Operations and Offshore Entities 8
- 8. Compliance and Enforcement 8
 - 8.1 Legal and Regulatory Compliance 8
 - 8.2 Internal Audit..... 9
 - 8.3 Management Review 9
 - 8.4 Policy Compliance 9
- 9. Information Security Incident Management..... 9
- 10. Business Continuity and Availability..... 9
- 11. Security Awareness and Training 10
- 12. Third-Party and Supply Chain Security 10
- 13. Policy Review and Maintenance 10

1. Purpose

This Information Security Master Policy ("the Policy") establishes ISEND GLOBAL's commitment to protecting the confidentiality, integrity, and availability of its information assets, systems, and the data of its customers and partners.

ISEND GLOBAL is a group of payment services providers across Singapore, Australia, the United States, Japan, and Korea. The nature of this business requires the highest standards of information security to safeguard customer funds, personal data, and transaction integrity.

This Policy:

- Defines the governance framework and accountability structure for information security
- Establishes the scope of the Information Security Management System (ISMS)
- Articulates management's commitment to achieving and maintaining ISO 27001:2022 certification and SOC 2 Type II attestation
- Provides the foundation from which all subordinate security policies, standards, and procedures derive their authority

2. Scope

2.1 Organizational Scope

This Policy applies to:

- All employees, contractors, consultants, temporary workers, and any third party acting on behalf of ISEND GLOBAL
- All information assets owned, managed, or processed by ISEND GLOBAL, regardless of format or location
- All business functions, processes, and systems that support the delivery of payment services

3. Information Security Policy Statement

ISEND GLOBAL is committed to protecting the information assets entrusted to it by customers, partners, regulators, and employees. Management recognizes that information security is a business-critical function that directly impacts customer trust, regulatory standing, and operational continuity.

To this end, ISEND GLOBAL will:

- Establish, implement, maintain, and continually improve an Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022
- Achieve and maintain SOC 2 Type II attestation against the Trust Services Criteria (Security, Availability, and Processing Integrity at minimum). SOC2 compliant audit completion slated for June 2026
- Protect customer personal data from unauthorized access, loss, or disclosure
- Ensure the availability and resilience of payment processing systems in accordance with defined recovery objectives
- Comply with all applicable legal, regulatory, and contractual security requirements across all jurisdictions of operation
- Ensure information security risks are identified, assessed, treated, and monitored through a formal risk management process
- Foster a culture of security awareness through regular training and clear accountability
- Respond to information security incidents in a timely, coordinated, and transparent manner

This Policy has been approved by the Executive Leadership and applies without exception across the entire organization.

4. Governance and Accountability

4.1 Roles and Responsibilities

Role	Responsibilities
Executive Leadership	Approve and endorse the Information Security Policy. Provide oversight of the ISMS. Ensure adequate resources are allocated for information security.
CISO	Own and maintain the ISMS. Report on security posture to executive leadership. Manage ISO 27001 and SOC 2 certification programs. Coordinate incident response. Approve subordinate policies.
Head of Engineering	Ensure security is embedded in the software development lifecycle. Oversee AWS infrastructure security controls. Maintain technical security standards.
Data Privacy Officer (DPO)	Ensure compliance with data protection obligations across all jurisdictions Singapore (PDPA), Japan (APPI), South Korea (PIPA), Australia (APPs), United States (GLBA). Manage data requests and cross-border transfer mechanisms.
Lead of Compliance	Ensure AML/CTF compliance policies across all payout and pay-in jurisdictions. Manage suspicious transaction reporting obligations. Liaise with regulators such as MAS, AUSTRAC, FinCEN, FSA, FSS in the licensed jurisdictions and liaison with banking partners in non-licensed jurisdictions.
All Employees & Contractors	Comply with this Policy and all subordinate policies. Report security incidents and suspected breaches. Complete mandatory security awareness training.

4.2 ISMS Committee

An Information Security Committee shall be established comprising the CISO, CTO, DPO, Head of Compliance, and a representative from each operational jurisdiction. The Committee shall:

- Meet no less than quarterly
- Review the risk register and treatment plans
- Review security incidents and near misses
- Approve changes to the ISMS scope and policies
- Review and endorse the annual internal audit program

5. Information Security Risk Management

Risk management is the foundation of ISEND GLOBAL's ISMS. The organization shall maintain a formal risk management process in accordance with ISO 27001:2022 Clause 6.

5.1 Risk Assessment

- Information security risks shall be identified and assessed at least annually, and upon significant changes to the business, technology, or threat landscape
- Risk assessments shall consider threats to the confidentiality, integrity, and availability of information assets

- The likelihood and impact of each identified risk shall be evaluated using the organization's defined risk scoring methodology
- Payment and remittance-specific risks — including transaction fraud, AML/sanctions evasion, API abuse, and third-party payment partner failures — shall be explicitly addressed

5.2 Risk Treatment

- All risks assessed above the organization's defined risk appetite threshold shall have a documented treatment plan
- Risk treatment options are: Treat (implement controls), Tolerate (accept with justification), Transfer (insurance / contractual), or Terminate (cease the activity)
- Residual risk shall be formally accepted by the risk owner

5.3 Statement of Applicability

ISEND GLOBAL shall maintain a Statement of Applicability (SoA) documenting the applicability or non-applicability — with justification — of all 93 controls defined in ISO 27001:2022 Annex A. The SoA is a mandatory certification artifact and shall be reviewed annually.

6. Information Security Objectives

In accordance with ISO 27001:2022 Clause 6.2, ISEND GLOBAL shall define measurable information security objectives aligned to this Policy. Objectives shall be:

- Consistent with the information security policy
- Measurable — with defined KPIs and target thresholds
- Monitored and reviewed at least annually by the ISMS Committee

Objective	Metric	Target
Zero critical unpatched vulnerabilities in production	Time to patch critical CVEs	< 72 hours
All personnel complete security awareness training	Training completion rate	100% annually
Payment system availability meets SLA targets	Uptime of payment processing services	≥ 99.9%
Security incidents resolved within SLA	Mean time to resolve (MTTR) by severity	P1: 24h P2: 48h P3: 72h
All high/critical risks have treatment plans	% of high risks with active treatment plans	100%
Third-party due diligence before onboarding and annual reassessment completed	% of critical suppliers assessed annually	100% of Tier 1 suppliers Tier 1 suppliers = vendors with: • Access to customer data / PII • Access to production systems • Payment processing involvement • Regulatory impact (e.g., fintech partners)

7. Subordinate Policy Framework

This Master Policy is supported by a suite of domain-specific policies. All subordinate policies derive their authority from this document and must be consistent with it. Non-compliance with any subordinate policy constitutes a violation of this Master Policy.

7.1 Domain-specific Policy List

The following policies are created based on the requirements of ISO 27001:2022 and for SOC2 Type II fulfillment.

SN	Policy Code	Policy Name	Category	Sub-Category	ISO 27001:2022 Controls	SOC 2 TSC
1	ISEND-PO-ISMS-001	Application Security Policy	IT	Technical	A.8.25, A.8.26, A.8.27, A.8.28	CC8.1, CC7.1
2	ISEND-PO-ISMS-002	Business Continuity Policy	IT	Technical	A.5.29, A.5.30	A1.1, A1.2, A1.3
3	ISEND-PO-ISMS-003	Data Protection Policy	IT	Technical	A.5.34, A.8.10, A.8.11, A.8.12	P Series, CC6.5
4	ISEND-PO-ISMS-004	Database Security Policy	IT	Technical	A.8.3, A.8.5, A.8.20	CC6.1, CC6.6
5	ISEND-PO-ISMS-005	Disaster Recovery Policy	IT	Technical	A.5.29, A.5.30, A.8.14	A1.2, A1.3
6	ISEND-PO-ISMS-006	Firewall Policy	IT	Technical	A.8.20, A.8.21, A.8.22	CC6.6
7	ISEND-PO-ISMS-007	Fraud Prevention & Detection Policy	IT	Non-Technical	A.8.16, A.5.7	CC7.2, PI1.3
8	ISEND-PO-ISMS-008	IT Risk Management Policy	IT	Technical	6.1.2, 6.1.3, A.5.7, A.5.8	CC3.1, CC3.2, CC9.1
9	ISEND-PO-ISMS-009	Network and Network Access Policy	IT	Technical	A.5.15, A.8.20, A.8.21, A.8.22, A.8.23	CC6.6, CC6.7
10	ISEND-PO-ISMS-011	Password Policy	IT	Technical	A.5.17	CC6.1
11	ISEND-PO-ISMS-012	Patch Management Policy	IT	Technical	A.8.8, A.8.19	CC7.1
12	ISEND-PO-ISMS-013	Personnel Security Policy	IT	Non-Technical	A.6.1, A.6.2, A.6.3, A.6.4, A.6.5	CC1.4
13	ISEND-PO-ISMS-014	Physical & Environmental Security Policy	IT	Non-Technical	A.7.1 – A.7.14	CC6.4
14	ISEND-PO-ISMS-015	System Administration Policy	IT	Technical	A.5.16, A.5.18, A.8.2, A.8.5	CC6.2, CC6.3
15	ISEND-PO-ISMS-016	Third Party Access Policy	IT	Non-Technical	A.5.19, A.5.20, A.5.21, A.5.22	CC9.2
16	ISEND-PO-ISMS-017	Violation & Enforcement Policy	IT	Non-Technical	A.5.32, A.6.4	CC1.1
17	ISEND-PO-ISMS-018	Vendor Management Policy	IT	Non-Technical	A.5.19, A.5.22, A.5.23	CC9.2

18	ISEND-PO-ISMS-019	IT Controls Risk & Impact Policy	IT	Technical	6.1.1, 6.1.2, A.5.8	CC3.1, CC4.1
19	ISEND-PO-ISMS-020	IT Security Policy (Master Policy anchor)	IT	Technical	A.5.1, A.5.2	CC1.2
20	ISEND-PO-ISMS-021	Privacy Policy	IT	Technical	A.5.34	P1 – P8
19	ISEND-PO-ISMS-022	Access Control Policy	IT	Technical		
20	ISEND-PO-ISMS-023	Incident Management Policy	IT	Technical		
21	ISEND-PO-ISMS-029	Data Retention Policy	IT	Technical		

7.2 AI Policy

Implementation of AI-assisted engineering for the SDLC process (excluding DevOps) are being planned. To start off with, AI Usage Policy has been drafted as Engineering Team Guidelines covering:

- Approved and prohibited use cases for AI tools within the organization
- Data handling restrictions — prohibition on inputting customer PII, transaction data, or confidential business information into external AI models
- AI-generated content review and approval requirements

7.3 Distributed Operations and Offshore Entities

ISEND GLOBAL operates distributed entities including BPO centers, client support operations, and sales and marketing offices across multiple jurisdictions. All such entities fall within the organizational scope of the ISMS as defined in Section 2.1, and all personnel engaged through them are subject to ISEND GLOBAL's information security policies without exception.

Endpoint Monitoring - ISEND GLOBAL shall deploy approved endpoint monitoring and activity tracking software on all company-issued devices across distributed operations. Monitoring scope, data retention, and permissible use of collected data SHALL be defined in the Endpoint Monitoring Standard and communicated to personnel prior to deployment. Monitoring implementations SHALL comply with applicable employment law and data protection regulations of the jurisdiction in which the entity operates.

Regulatory Jurisdiction - The CISO and DPO SHALL maintain a current assessment of information security and data protection obligations applicable to each operational jurisdiction. This includes classification of each entity's role under applicable data protection law, and ensuring appropriate cross-border data transfer mechanisms are in place for flows between ISEND GLOBAL entities and jurisdictions.

8. Compliance and Enforcement

8.1 Legal and Regulatory Compliance

ISEND GLOBAL shall identify, document, and comply with all applicable legal, regulatory, and contractual information security requirements across all jurisdictions of operation. The Compliance Register shall be maintained by the CISO in conjunction with the Head of Compliance and reviewed at least annually.

8.2 Internal Audit

Internal audits of the ISMS shall be conducted at planned intervals (minimum annually) in accordance with ISO 27001:2022 Clause 9.2. Audit findings shall be documented and tracked to resolution through the Nonconformity and Corrective Action Log.

8.3 Management Review

Executive leadership shall conduct a formal management review of the ISMS at least annually in accordance with ISO 27001:2022 Clause 9.3. Review inputs and outputs shall be documented.

8.4 Policy Compliance

Violations of this Policy or any subordinate policy may result in disciplinary action up to and including termination of employment or contract, and where applicable, civil or criminal proceedings. Non-compliance findings shall be reported to the CISO and escalated as appropriate.

9. Information Security Incident Management

All personnel are required to report suspected or confirmed information security incidents immediately to infosec@isendglobal.com shall maintain a formal Incident Management Policy (ISP-005) defining:

- Incident classification and severity levels
- Escalation paths and response timelines by severity
- Regulatory breach notification obligations (MAS 24-hour notification, APRA 24-hour, GDPR/PDPA 24-hour equivalents where applicable)
- Post-incident review and lessons-learned process

No personnel shall attempt to conceal, delay reporting, or independently remediate a security incident without engaging the security response team.

10. Business Continuity and Availability

Given the critical nature of payment and remittance services, ISEND GLOBAL shall maintain Business Continuity and Disaster Recovery capabilities. Recovery objectives are defined in the Business Continuity & DR Policy (ISP-012) and shall reflect:

- RTO and RPO targets per service criticality tier
- BC and DR location
- AWS architecture requirements

11. Security Awareness and Training

All personnel shall complete mandatory security awareness training - Tier1 and Tier2 both:

- Upon commencement of employment or engagement
- Annually thereafter
- When significant policy or threat landscape changes occur

Tier1 training shall cover at minimum: phishing and social engineering, acceptable use, password hygiene, data classification and handling, and incident reporting procedures.

Tier2 training shall cover department/role-specific training provided to personnel of particular departments.

12. Third-Party and Supply Chain Security

All third parties — including payment partners, technology vendors, cloud service providers, and professional services firms — that access, process, or store ISEND GLOBAL information shall be subject to security due diligence prior to engagement and on a periodic basis thereafter, in accordance with the Third-Party & Supplier Security Policy (ISP-011).

Material third-party relationships shall be governed by appropriate contractual security obligations including data processing agreements, audit rights, and incident notification requirements.

13. Policy Review and Maintenance

This Policy shall be reviewed at least annually, or upon:

- Significant changes to the organization's structure, services, or technology
- Material changes to the threat landscape or regulatory environment
- Findings from internal audits, management reviews, or security incidents
- Regulatory or certification body requirements

All revisions shall be tracked in the Document Control Register, approved by the CISO and CEO, and communicated to all personnel.

END OF DOCUMENT — ISEND-InfoSec-MASTER-001 v1.3 — CONFIDENTIAL